HealthConnect — Compliance & Security Requirements

Document type: Regulatory / Security Reference
Version: 1.4
Owner: Information Governance & Security Team
Applies to: All HealthConnect patient-facing digital products

---

1. HIPAA Compliance Requirements

1.1 Protected Health Information (PHI) Definition

PHI in the HealthConnect context includes any data that can identify a patient and relates to their health condition, treatment, or payment. This includes:

- Name, date of birth, address, phone number, email
- MRN (Medical Record Number) and NHS number
- Appointment dates and clinical notes
- Lab results, diagnostic reports, and imaging
- Medication and prescription history
- Insurance and billing information
- IP addresses and device identifiers when combined with health data

1.2 Minimum Necessary Standard

Rule: Users and services may access only the minimum PHI required to perform their function.

Role	Permitted PHI access
Patient	Own records only (5-year window by default)
Carer (proxy)	Patient's records only after written consent + admin approval
GP / Clinician	Patients on their panel + on-call coverage
Front Desk Admin	Appointment and demographic data only; no clinical notes
Clinical Informatics	Aggregate, de-identified data only; no individual-level access
Audit Service	Read-only access to audit event stream (no PHI content, only metadata)

Implementation requirements:

- Row-level security in PostgreSQL enforced by Auth Service claims
- FHIR Adapter applies patient-scoped token filtering before returning Epic data
- Clinical Informatics queries run against de-identified replica; no direct prod access

1.3 Encryption Requirements

Data state	Requirement	Implementation
At rest — database	AES-256	RDS encryption with AWS-managed KMS key
At rest — files/attachments	AES-256	S3 SSE-KMS with customer-managed key (CMK)

At rest — backups	AES-256	RDS automated backup encryption inherited
In transit — external	TLS 1.3 minimum	API Gateway policy; Strict-Transport-Security header
In transit — internal (VPC)	TLS 1.2 minimum	Service mesh enforced by security group rules
PHI identifiers	Tokenised	MRN stored as token; plain value only at FHIR Adapter boundary

Key rotation: Customer-managed keys rotated annually. KMS rotation alerts monitored by Security team.

1.4 Audit Logging

Rule: Every access to PHI must generate an immutable audit record.

Required fields per audit event:

```
{
  "eventId": "uuid-v4",
  "timestamp": "ISO-8601 UTC",
  "actorType": "patient | proxy | clinician | admin | system",
  "actorMrnToken": "sha256-tokenised-mrn",
  "patientMrnToken": "sha256-tokenised-mrn",
  "action": "READ | WRITE | DELETE | DOWNLOAD | LOGIN | LOGOUT",
  "resourceType": "Appointment | DiagnosticReport | MedicationRequest | ...",
  "resourceId": "FHIR-resource-id",
  "ipAddress": "IPv4 or IPv6",
  "userAgent": "browser/version",
  "outcome": "SUCCESS | FAILURE"
}
```

Retention: 7 years (HIPAA §164.530(j)).
Storage: DynamoDB (hot, 90 days) → S3 Glacier (cold, remainder of 7-year period).
Immutability: DynamoDB point-in-time recovery enabled; S3 object lock (compliance mode) on Glacier bucket.
Access to audit logs: Restricted to Security team and Compliance Officer; query via audit console only.

1.5 Patient Rights

Right	Portal feature	Implementation
Right of Access	"Download my records"	Server-side PDF generation from FHIR resources; pre-signed S3 URL (5 min TTL)
Right to Correct	"Request correction" form	Creates a `Flag` resource in Epic; admin workflow to apply and sign off
Right to Restrict	Consent management panel	Preference flags stored in Auth Service; propagated to FHIR Adapter on each request

Right to an Accounting	Audit log export	Patient can request their own audit trail via support ticket (7-day SLA)

1.6 Business Associate Agreements (BAA)

BAAs must be signed and current before PHI is transmitted to any third-party processor:

Vendor	Purpose	BAA status
Amazon Web Services	All cloud infrastructure	Signed — AWS BAA addendum
Twilio	SMS notifications	Signed — Twilio HIPAA BAA
SendGrid (Twilio)	Email notifications	Covered under Twilio BAA
Doxy.me	Telehealth video	Signed — Doxy.me BAA
Stripe	Co-payment processing	Signed — Stripe BAA (financial data; no clinical PHI transmitted)

Requirement: Any new vendor integration must have a BAA executed before the feature moves to staging.

---

2. GDPR Compliance (EU Patients)

2.1 Scope

GDPR applies to any patient registered at a Meridian Health clinic in an EU member state or who accesses the portal from an EU territory.

2.2 Lawful Basis

Processing purpose	Lawful basis
Delivering healthcare	Article 9(2)(h) — healthcare provision
Clinical communications	Legitimate interests (Article 6(1)(f))
Marketing communications	Explicit consent (Article 6(1)(a))
Research / analytics	Explicit consent or anonymous aggregation

2.3 Consent Management

Each patient must be able to independently toggle:

1. **Clinical communications** — appointment reminders, lab result notifications (required for portal access; cannot be disabled without account closure)
2. **Research** — use of anonymised data for Meridian Health research programmes
3. **Marketing** — newsletters, health campaigns, partner offers
4. **Wearable sync** (Phase 2) — Apple Health / Google Fit data integration

Implementation:

- Consent preferences stored in Auth Service with timestamp and version of terms accepted

- Consent withdrawal must take effect within 24 hours across all channels
- Consent history retained for 3 years for regulatory evidence

2.4 Data Residency

Rule: EU patient data (any record where `Patient.address.country` is an EU member state) must not be stored, processed, or transmitted outside of the EU.

Implementation:

- EU patient records routed to `eu-west-1` (Dublin) AWS region
- FHIR Adapter for EU patients runs in `eu-west-1`
- S3 buckets for EU attachments locked to `eu-west-1` with no replication to US regions
- Twilio and SendGrid: EU data processed via their EU infrastructure endpoints only

2.5 Right to Erasure

Rule: Non-clinical data can be deleted on request. Clinical records must be retained per NHS/clinical record retention schedules and cannot be erased.

Data category	Erasure possible?	Retention minimum
Account / demographic	Yes	None (once patient ends care relationship)
Appointment history	Yes (if >2 years old and no active care plan)	2 years
Clinical notes, lab results	No	10 years (NHS Records Management Code)
Audit logs	No	7 years (HIPAA)
Marketing consent records	Yes (the consent, not the activity log)	3 years evidence copy

Process: Erasure requests submitted via "My Account → Data & Privacy → Request data deletion". Target: completed within 30 days.

---

3. Accessibility Requirements (WCAG 2.1 AA)

3.1 Mandatory Standards

All patient-facing screens must meet WCAG 2.1 Level AA. This includes:

Criterion	Requirement
1.1.1 Non-text content	All images have meaningful alt text; decorative images have `alt=""`
1.3.1 Info and relationships	Semantic HTML; form fields have associated `<label>` elements
1.4.3 Contrast (minimum)	Text contrast ratio ≥ 4.5:1; large text ≥ 3:1
1.4.4 Resize text	Text resizable to 200% without loss of content or functionality

2.1.1 Keyboard	All functionality operable by keyboard; no keyboard traps
2.4.3 Focus order	Logical tab order on all pages
2.4.7 Focus visible	Visible focus indicator on all interactive elements
3.3.1 Error identification	Form errors described in text, not colour alone
4.1.2 Name, role, value	All UI components expose accessible name and role

3.2 Screen Reader Support

- **JAWS** (Windows) — tested with Chrome and Edge
- **VoiceOver** (macOS / iOS) — tested with Safari
- **TalkBack** (Android) — tested with Chrome Mobile

All modals, toasts, live result updates must use appropriate ARIA live regions.

3.3 Minimum Visual Standards

- Font size: minimum 16px body text; 14px allowed for legal/disclaimer text with explicit exception approval
- Line height: minimum 1.5× for body text
- Touch targets: minimum 44×44px on mobile (WCAG 2.5.5 Target Size)
- No colour-only information: status indicators must use icon + colour + text label

3.4 CI Enforcement

- axe-core integrated into Storybook component tests — must have 0 violations to merge
- Lighthouse accessibility score ≥ 90 on all pages (automated check in GitHub Actions)
- Manual JAWS + VoiceOver audit required before each major release

---

4. Security Controls

4.1 Authentication

Control	Requirement
Password complexity	Minimum 10 characters; at least 1 uppercase, 1 number, 1 special character
MFA	Mandatory for all patient accounts (SMS OTP or TOTP authenticator app)
Session timeout	Web: 15 min inactivity; Mobile: 30 min; Clinical staff: 8 min
Account lockout	5 consecutive failures → account locked; unlock via email verification link
Concurrent sessions	Maximum 3 active sessions per patient account; new session logs out oldest

4.2 API Security

- All endpoints protected by JWT validation at API Gateway
- Rate limiting: 100 requests/min per patient token; 20 requests/min on auth endpoints
- WAF rules: OWASP Top 10 ruleset; geo-blocking as required by legal
- CORS policy: allow-list of known portal domains only

4.3 Vulnerability Management

- Dependabot enabled for all repositories; critical CVEs must be patched within 7 days
- OWASP ZAP DAST scan on every deployment to staging; blocking on High/Critical findings
- Annual third-party penetration test; findings tracked in Security team Jira project
- Container images scanned with Trivy in CI; no Critical CVEs allowed in production images

4.4 Incident Response

Severity	Definition	Response time	Notification
P1 — Critical	PHI breach or system unavailable	15 min	On-call + CISO + Legal
P2 — High	Partial service degradation, possible data exposure	1 hour	On-call + Product lead
P3 — Medium	Non-PHI issue, minor degradation	4 hours	Engineering team
P4 — Low	Cosmetic or minor functional issue	Next business day	Ticket only

HIPAA Breach Notification Rule: if a confirmed breach affects >500 patients in a US state, HHS must be notified within 60 days and affected patients within 60 days of discovery.